



Security Incident Report

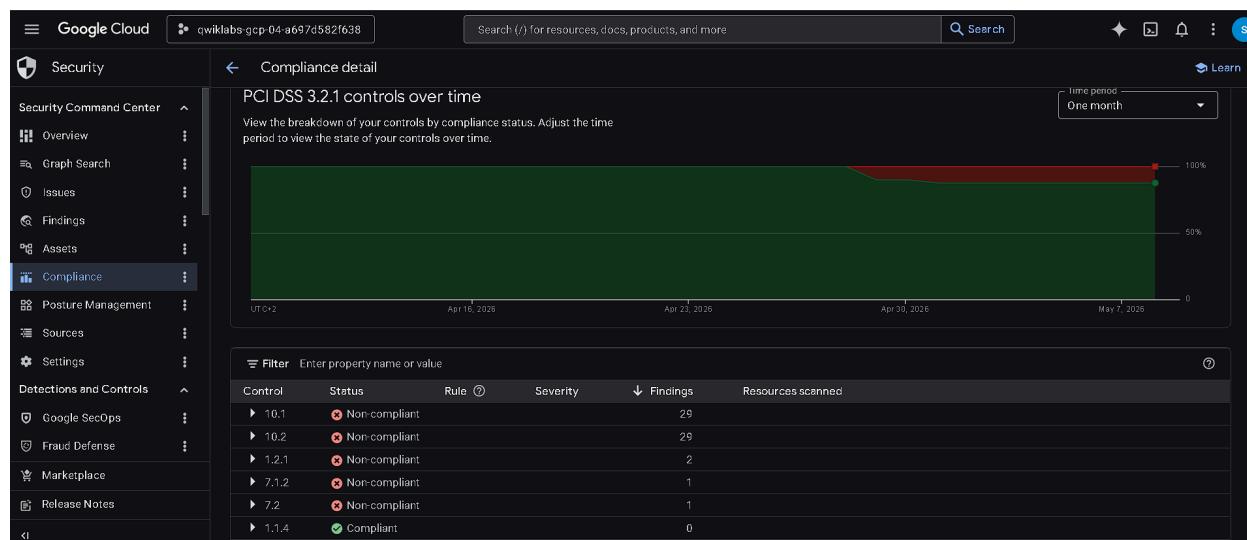
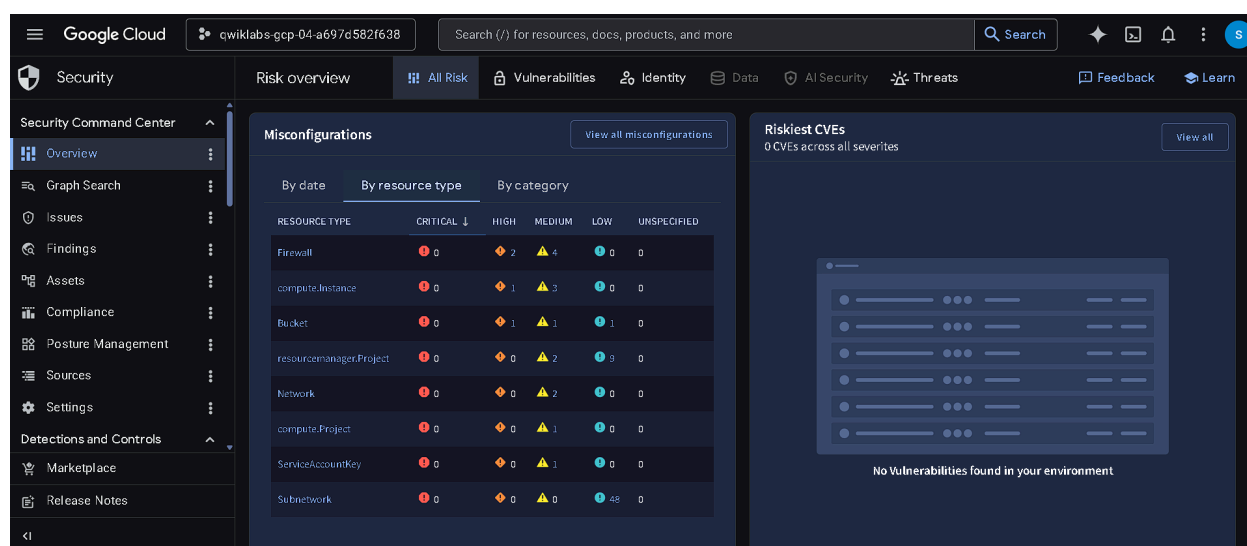
Table of contents

Security Incident Report	1
Table of contents	1
Executive summary	2
Response and remediation	3
Containment and eradication measures	3
Recovery measures	4
Recommendation	6
Verification	

Executive summary

Cymbal Retail recently experienced a significant data breach involving unauthorized access to sensitive customer information and credit card data. The incident originated from a series of security misconfigurations and vulnerabilities across the Google Cloud environment.

Investigation into the “Investigation” section of the template revealed that a virtual machine, `cc-app-01`, was compromised by malware and was using a default service account with full API access. Additionally, a Cloud Storage bucket containing sensitive data was found to be publicly accessible via an insecure Access Control List (ACL).

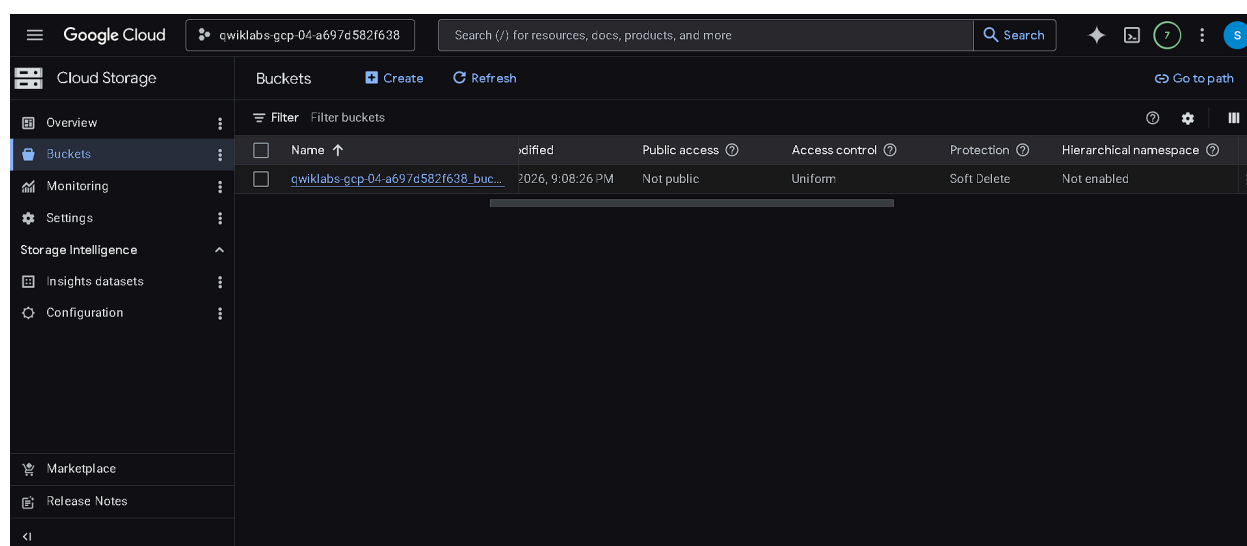


Further analysis identified that the network was highly vulnerable due to firewall rules that allowed unrestricted SSH and RDP connections from any IP address on the internet. These issues resulted in non-compliance with the PCI DSS 3.2.1 framework. To remediate the threat, the security team isolated affected systems and restored them using known-clean snapshots. By implementing uniform bucket-level access and restricted firewall rules, the team successfully eliminated the vulnerabilities. The remediation effort was verified through a final compliance report, confirming that the security posture has been significantly enhanced.

Response and Remediation

1. Containment and Eradication

1. The compromised VM `cc-app-01` was immediately shut down to prevent the malware from communicating with malicious domains.
2. Public access to the Cloud Storage bucket was revoked by removing the `allUsers` principal and enabling public access prevention.
3. Overly permissive firewall rules for ICMP, RDP, and SSH were deleted to close unauthorized entry points into the VPC network.



2. Recovery Measures

1. A new, secure virtual machine named `cc-app-02` was deployed using a trusted system snapshot.
2. The new instance was hardened by disabling its public IP address and enabling Secure Boot to protect against unauthorized code.
3. Storage bucket management was converted to uniform access control to ensure consistent permission enforcement.
4. A new firewall rule, `limit-ports`, was created to restrict SSH access exclusively to the authorized Google Cloud IAP IP range of `35.235.240.0/20`.
5. Logging was enabled for both the new `limit-ports` rule and existing internal rules to ensure full auditability of network traffic.

Google Cloud | qwiklabs-gcp-04-a697d582f638 | Search (/) for resources, docs, products, and more

Compute Engine

← Edit cc-app-02 instance

Overview
Security risk overview
Virtual machines
VM instances
Instance templates
Sole-tenant nodes
Machine images
TPUs
Committed use discou...
Reservations
Migrate to Virtual Mac...
Marketplace
Release Notes

Local disks
None

Security and access

Shielded VM ⓘ
Turn on all settings for the most secure configuration.

☒ Turn on Secure Boot ⓘ
☒ Turn on vTPM ⓘ
☒ Turn on Integrity Monitoring ⓘ

SSH Keys
These keys allow access only to this instance, unlike project-wide SSH keys.
[Learn more](#)

☐ Block project-wide SSH keys
When checked, project-wide SSH keys cannot access this instance. [Learn more](#)

Save Cancel

Google Cloud | qwiklabs-gcp-04-a697d582f638 | Search (/) for resources, docs, products, and more

← Create an instance | Create VM from... | Equivalent code

Machine configuration
e2-medium, us-west1
OS and storage
cc-app01-snapshot
Data protection
Snapshot schedules
Networking
1 network interface
Observability
Security
Advanced

Alias IP ranges
+ Add IP range

External IPv4 address ⓘ
Filter Type to filter
None
Ephemeral
Reserve static external IP address

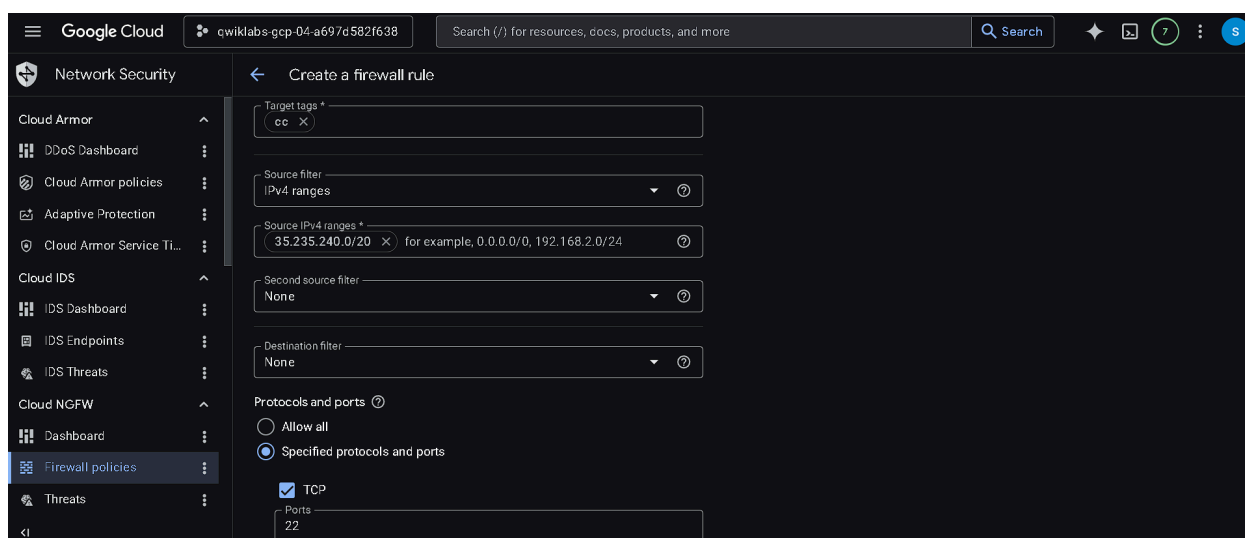
Dynamic Network Interfaces ⓘ
Add a Dynamic Network Interface

Monthly estimate
\$25.46
That's about \$0.03 hourly
Pay for what you use: no upfront costs and per second billing

Item	Monthly estimate
2 vCPU + 4 GB memory	\$24.46
10 GB balanced persistent disk	\$1.00
Snapshot schedule	Cost varies
Total	\$25.46

[Compute Engine pricing](#)
Less

Create Cancel Equivalent code



Recommendations

1. Transition to Custom Service Accounts: The organization should immediately stop using default service accounts for VM instances. Instead, custom service accounts with the Principle of Least Privilege should be implemented to ensure identities only have the specific API access required for their function.

2. Automated Security Monitoring: It is recommended that Cymbal Retail implements automated security posture monitoring within the Security Command Center. This will provide real-time alerts if a storage bucket is made public or if firewall rules are modified to allow broad internet access, preventing future data breaches.

Verification

Final assessment of the environment using SSC to confirm that all major vulnerabilities have been remediated.

Google Cloud

qwiklabs-gcp-04-a697d582f638

Search (/) for resources, docs, products, and more

Search

11

S

Security

Risk overview

All Risk

Vulnerabilities

Identity

Data

AI Security

Threats

Feedback

Learn

Security Command Center

Overview

Graph Search

Issues

Findings

Assets

Compliance

Posture Management

Sources

Settings

Detections and Controls

Marketplace

Release Notes

Things are looking good!

We couldn't find any critical or high threats over the last week.

Misconfigurations

View all misconfigurations

By date

By resource type

By category

RESOURCE TYPE	CRITICAL ↓	HIGH	MEDIUM	LOW	UNSPECIFIED
resourceManager.Project	0	0	2	3	0
Network	0	0	2	0	0
compute.Project	0	0	1	0	0
ServiceAccountKey	0	0	1	0	0
Subnetwork	0	0	0	48	0
Bucket	0	0	0	1	0

Riskiest CVEs

0 CVEs across all severities

View all

No Vulnerabilities found in your environment